Relatório de Projeto — AlertaChuva SP

Iniciativa CitizenTech | Prevenção e Resiliência Urbana

Ideia Escolhida (Inspiração): Sistemas de previsão de enchentes, deslizamentos, incêndios e ondas de calor com alertas direcionados à população — focado em **chuva forte e alagamento** na cidade de São Paulo.

1. Quem é o cidadão e qual é o problema

Cidadão afetado: Quem mora ou trabalha em áreas sujeitas a alagamento e enxurrada em São Paulo, em especial famílias de baixa renda, crianças pequenas e idosos, que têm menos recursos para reagir (guardar pertences, sair de casa, buscar abrigo).

Problema: A chuva forte chega mais rápido do que a informação. O morador de área de risco costuma saber que a água está subindo quando ela já está na rua. Faltam avisos **curtos, direcionados à sua região e no nível de risco que ele considera relevante**, que funcionem mesmo com conectividade ruim.

2. Evidência (Dado Público)

Estudo IBGE + CEMADEN — "População em áreas de risco no Brasil" (base: Censo 2010, publicado em 2018):

- **8,3 milhões de pessoas** moravam em áreas com risco de inundações, enxurradas e deslizamentos, distribuídas em **872 municípios**.
- A **capital paulista** destaca-se entre as maiores: **674.329 pessoas** em áreas de risco, ficando atrás apenas de Salvador.
- Cerca de **20,3%** dessa população vivia em aglomerados subnormais (1,7 milhão de pessoas), e crianças e idosos somam **17,8%** dos moradores dessas áreas — os grupos que mais dependem de aviso antecipado.

Fonte: IBGE Agência de Notícias (28/06/2018). Limitação: números baseados no Censo 2010; a estimativa atual é provavelmente maior.

3. Objetivos de Desenvolvimento Sustentável (ODS)

ODS	Meta	Como o projeto contribui
11 - Cidades e Comunidades Sustentáveis	**11.5:** Reduzir mortes e afetados por desastres hídricos, focando nos vulneráveis.	Alerta antecipado e regionalizado, disparado de acordo com o nível de risco escolhido pelo próprio morador.
13 - Ação Contra a Mudança Global do Clima	**13.1 & 13.3:** Fortalecer resiliência e sistemas de alerta precoce.	Converte previsão meteorológica aberta em ação local; ganha relevância com o aumento de eventos extremos.
10 - Redução das Desigualdades	Inclusão de grupos vulneráveis.	Serviço gratuito, com coleta mínima de dados e projetado para canais leves (UDP, mensagens curtas).

4. Solução e Fluxo Operacional

ARQUITETURA DE DADOS E COMUNICAÇÃO

```
Open-Meteo (JSON)  ->  previsao.py (classifica o risco)
                                |
 Cidadão (web) -> API Flask --+--> MySQL (inscrições, áreas, histórico)
                                |
 Operador ---- dispara ------>+--> UDP assinado --> receptor (sirene / painel / celular)
```

Fluxo de Execução:

1. O cidadão consulta o risco da região (previsão real das próximas 24h) e se inscreve com consentimento.
2. O operador (Defesa Civil ou associação de moradores) dispara o alerta para determinada área.
3. A API consulta a previsão, calcula o nível, conta os inscritos que aceitam aquele nível e envia **um datagrama UDP assinado** ao receptor, que confirma com ACK. O resultado fica gravado no histórico e no log.

Hipóteses a validar com a comunidade: (a) o morador prefere alerta por nível escolhido a avisos genéricos; (b) os limiares de chuva (30/60/100 mm em 24 h) combinam com a realidade de cada bairro; (c) sirene ou painel comunitário alcança quem não tem smartphone. *(Nota: os limiares atuais são ilustrativos).*

5. Segurança e Privacidade (LGPD)

- **Coleta mínima (LGPD, art. 6º, III):** Coleta-se apenas apelido, área (sem endereço completo), nível desejado, data do consentimento e o *hash* do token. Não são coletados nome completo, CPF, telefone nem localização exata.
- **Base legal e direitos do titular:** Consentimento explícito e registrado (art. 7º, I e art. 8º), mediante checkbox obrigatório e registro de `consentimento_em` no banco. Direitos de acesso (`GET`), correção (`PUT`) e eliminação (`DELETE`) estão implementados na API (art. 18). O apelido é tratado como dado pessoal por poder identificar o cidadão em determinados contextos.

- **Medidas técnicas de segurança (art. 46):** Armazenamento de credenciais em arquivo `.env`, usuário do banco sem privilégios DDL, consultas estritamente parametrizadas, validação por lista de permissão, mensagens de erro genéricas, tokens armazenados via hash, comparação de tokens em tempo constante, limitação de taxa de requisições (rate limiting), política CSP rígida e alertas UDP assinados. O IP é mantido apenas em memória para controle de requisições; logs não contêm dados pessoais nem chaves.
- **Limites do protótipo:** O envio de alertas para pessoas reais exigiria canais de contato diretos (SMS, WhatsApp, app), necessitando de novos dados, novo consentimento e Elaboração de Relatório de Impacto à Proteção de Dados (RIPD). No escopo atual, utiliza-se um receptor UDP de demonstração.

6. Análise de Ameaças e Mitigações

Ameaça 1 — Injeção de SQL e de Script (Entradas Maliciosas)

Cenário: Um atacante envia `x'; DROP TABLE inscricoes;--` no apelido, um `area_id` malicioso como `1 OR 1=1`, ou tags `<script>` para execução de código no navegador do operador.

Impacto: Vazamento, alteração ou exclusão de dados; sequestro da sessão do operador.

Mitigações:

- Todas as consultas utilizam parâmetros (`%s`) em `db.py`.
- O módulo `validar.py` aplica validação estrita: regex no apelido, inteiros estritos, níveis em lista fixa, rejeição de campos extras e limite de corpo de 4 KB.
- Interface web utiliza exclusivamente `textContent` (evitando `innerHTML`) e a CSP bloqueia scripts inline.
- Usuário do banco de dados possui permissões restritas (apenas SELECT, INSERT, UPDATE, DELETE).

Verificação: Testes unitários e de integração retornaram status HTTP 422 para todas as entradas maliciosas.

Ameaça 2 — Acesso Indevido a Dados de Terceiros e Abuso da API

Cenário: Tentativa de leitura, alteração ou exclusão de inscrições de outros cidadãos via IDs sequenciais, listagem não autorizada de inscritos ou inundações de cadastros na API.

Impacto: Violação de privacidade (LGPD), cancelamento indevido de alertas, spam e negação de serviço.

Mitigações:

- Cada inscrição gera um **token aleatório de 192 bits**, exibido uma única vez e armazenado apenas como hash. Requisições sem o token correto retornam 403.
- Ações de operador (listagem, histórico, disparo) exigem a `ADMIN_API_KEY` com verificação em tempo constante.
- Rate limiting por IP (429): 10 cadastros/min, 30 consultas de risco/min e 20 disparos/min.
- Respostas de erro genéricas que não revelam o estado interno do sistema.

Verificação: Validação de 403 para tokens incorretos e 429 para requisições excedentes.

Ameaça 3 — Alerta Falso ou Repetido (Falsificação e Replay UDP)

Cenário: Atacante na rede envia datagramas UDP forjando risco crítico ou reenvia alertas antigos válidos (ataque de replay).

Impacto: Pânico, descrédito do sistema e decisões erradas em situações de emergência real.

Mitigações (`udp_alertas.py`, `receptor_udp.py`):

- Disparos assinados digitalmente com **HMAC-SHA256** usando a chave `ALERTA_SEGREDO`. Assinaturas inválidas são descartadas.
- Controle de **carimbo de tempo** (tolerância de 5 minutos) e **ID único** por mensagem. Alertadores expirados ou repetidos são rejeitados.
- Datagramas inválidos são descartados silenciosamente sem resposta ACK para evitar enumeração da rede.
- O payload contém apenas área, nível, dados de chuva e contagem de inscritos, sem dados pessoais.

7. Limitações e Próximos Passos

- **Calibragem de Limiares:** Os parâmetros de chuva atuais são ilustrativos; devem ser calibrados com dados históricos e integração com CEMADEN, INMET e Defesa Civil.
- **Infraestrutura de Produção:** O limitador de requisições atual é em memória (instância única). Para produção, recomenda-se a adoção de Redis, proxy reverso e obrigatoriedade de HTTPS.
- **Canais de Entrega Reais:** Expansão para envio via SMS, notificações push em aplicativo próprio, mensagens via WhatsApp e integração com sirenes comunitárias físicas.
- **Validação Comunitária:** Realização de testes de campo e pesquisas com moradores locais para validar as hipóteses operacionais levantadas na Seção 4.